Cyber-Security Awareness: How to Stay Safe Online

Module: COM4401 Foundations of Computer Science and Academic Skills

University: University of Greater Manchester

Team: The Avengers

Group members: Marcus Weeks, Charlie Broughton, Sorena Golbarg Lisar, Nah'Kajsha Reid

Date: October 2026

Contents

Introduction....3

1. Password Hygiene....3

1.1 What makes a password strong....4

1.2 Password managers....4

1.3 Credential reuse and credential stuffing....5

1.4 Where the numbers come from....5

1.5 Password hygiene at a glance....5

2. Two-Factor Authentication....6

2.1 Authentication factors....6

2.2 Comparing SMS codes, authenticator apps and hardware security keys....6

2.3 Evidence for the effectiveness of MFA....7

2.4 Why SMS can still be used....7

3. Phishing and Social Engineering....7

3.1 Phishing and its Different Forms....7

3.2 Psychological Techniques....9

3.3 Indicators of Phishing....9

3.4 What Should Someone Do if They Suspect or Click Phishing?....10

4. Safe Use of Devices....11

4.1 Keeping Software Updated: Vulnerabilities, Patches, and Exploits....11

4.2 Device Encryption, Screen Locks, and Security Software....12

4.3 Risks of Installing Software from Unofficial Sources....12

4.4 Risks of Unknown USB Devices and Public Charging Points....12

Conclusion....13

Reference List....13

Introduction

Most of us now bank, shop, work and keep in touch online, and every one of those accounts is something an attacker can target. In 2025, 43% of UK businesses identified a cyber security breach or attack in the previous 12 months (Department for Science, Innovation and Technology, 2025). Of the businesses that had one, 65% named phishing as the most disruptive type of attack (DSIT, 2025).

Verizon's 2025 Data Breach Investigations Report found that human involvement in breaches remains high (Verizon, 2025). An estimated 43% to 51% of users reuse the same password across different sites (Das et al., 2014), and in 2025 Verizon found that only 49% of a typical person's passwords were different from each other (Langlois, 2025). In 2023 an attacker got into 23andMe accounts using login details that people had reused after earlier, unrelated breaches (Information Commissioner's Office, 2025).

This report relies mainly on official bodies. The National Cyber Security Centre (NCSC) is part of GCHQ and helps businesses, the public sector and individuals protect the online services and devices they depend on. Its stated mission is to make the UK the safest place to live and work online (National Cyber Security Centre, N.D.c).

Section 1 covers passwords. Section 2 covers two-factor and multi-factor authentication, which add another layer of protection by asking for more than a password before anyone can get into an account. Authentication can use something a person knows, has or is (NIST, 2025), and the different methods give different levels of protection.

Section 3 covers phishing, a form of social engineering in which attackers impersonate trusted individuals or organisations to deceive victims into revealing sensitive information, transferring money or carrying out unsafe actions (National Institute of Standards and Technology, n.d.). Phishing takes several forms and often relies on psychological manipulation to make a victim more likely to respond.

Section 4 covers devices. Laptops, mobile phones and tablets hold personal, financial and work information, and if a device is not safe, someone can hack it and steal that information. A password alone cannot keep a device safe, so several layers of protection need to work together: regular software updates, screen locks and encryption, downloading apps only from official stores, and care with unknown USB devices and public chargers. When a weakness in software becomes public, attackers can use it to attack devices that have not been updated (NCSC, 2021d).

1. Password Hygiene

Section owner: Marcus Weeks

Almost every online account starts with a password, which makes passwords one of the easiest ways in for an attacker. Verizon's 2025 Data Breach Investigations Report found that stolen or compromised login details were the starting point in 22% of the breaches it studied (Langlois, 2025).

1.1 What makes a password strong

For years the advice was to make passwords complicated, with capital letters, numbers and symbols, and to change them every few months. That advice backfired. People fall back on predictable tricks to meet complexity rules, like swapping the letter “o” for a zero or adding “!” to the end. Attackers know these tricks and use them to shape their guessing, so forcing complexity ends up producing more predictable passwords (NCSC, 2021a). Most of us also have lots of passwords, and memorising lots of complex ones is close to impossible (NCSC, N.D.a).

In the UK, the National Cyber Security Centre (NCSC) now recommends joining three random words together. That gives a password long enough and strong enough for most accounts, and far easier to remember. The NCSC also says writing a password down is fine, as long as you keep it somewhere safe (NCSC, N.D.a).

In the US, the National Institute of Standards and Technology (NIST) has gone further. Its latest guidance says services must require at least 15 characters for a password used on its own. They must not force a mix of character types, and must not make people change passwords on a schedule unless there is evidence the password has been leaked. Services should check new passwords against lists of common and already-leaked ones instead (National Institute of Standards and Technology, 2025).

A study of 15 different password rules with over 20,000 participants found that rules based on length can produce passwords that are both stronger and easier to use than rules based on complexity (Shay et al., 2016). The NCSC makes the same point about length. A password made of several words comes out longer, without relying on predictable add-ons like an “!” at the end (NCSC, 2021a).

1.2 Password managers

Remembering a different password for every account is difficult, even with three random words (NCSC, N.D.b). A password manager takes that job off you. You log in once with one strong main password, and the manager stores the rest, creates new random passwords and fills them in for you (NCSC, N.D.b).

Every account gets its own password, so one leak does not open the others. Autofill only works on the genuine website, which gives some protection against fake login pages, and many managers warn you if one of your passwords turns up in a data breach (NCSC, N.D.b). NIST now says websites must allow password managers and autofill, because password managers make people more likely to choose stronger passwords (NIST, 2025).

They are not perfect. A security test of 13 popular password managers found that some generated passwords were not truly random, along with insecure default settings and other weaknesses, although the managers had improved over the previous five years (Oesch and Ruoti, 2020). Interviews with 30 users found that people using the password manager built into their browser were mostly after convenience, while people who installed a separate one cared more about security. Earlier data suggested the convenience group more often kept weak or reused passwords (Pearman et al., 2019).

Even with those weaknesses, the NCSC still recommends password managers. Its advice is to turn on 2-step verification first, as the most important step, then use a password manager on top of it (NCSC, N.D.b).

1.3 Credential reuse and credential stuffing

Credential reuse means using the same password on more than one account. A study of leaked passwords from 11 websites estimated that 43% to 51% of users reuse the same password across sites. Changing a password slightly between sites did not help much. Using a known password from one site, the researchers' method guessed 30% of these tweaked passwords within 100 attempts (Das et al., 2014). More recent Verizon data found that, in the median case, only 49% of a person's passwords were different from each other (Langlois, 2025).

Reuse is what makes credential stuffing work. Attackers take usernames and passwords leaked in one breach and use software to try them on many other sites. Verizon found that credential stuffing made up a median of 19% of all daily login attempts at the organisations it studied, rising to 25% at large companies (Langlois, 2025).

Between April and September 2023, an attacker used login details stolen from other, unrelated breaches to get into accounts on the genetic testing site 23andMe. The attack gave access to the personal information of 155,592 people in the UK, potentially revealing names, locations, ethnicity, family trees and health reports. In June 2025 the UK Information Commissioner's Office fined 23andMe £2.31 million for failing to protect that data (Information Commissioner's Office, 2025).

1.4 Where the numbers come from

The 22% figure at the start of this section comes from Verizon's 2025 Data Breach Investigations Report, and covers the known ways attackers got in across 9,891 breaches (Langlois, 2025). It is taken from the write-up by Verizon's own research team, which is the original source.

1.5 Password hygiene at a glance

Do	Don't
Use three random words, or at least 15 characters (NCSC, N.D.a; NIST, 2025)	Rely on symbols and number swaps like "P@ssw0rd" (NCSC, 2021a)
Use a different password for every account (NCSC, N.D.b)	Reuse a password, even with small changes (Das et al., 2014)
Store them in a password manager, or write them down and keep them somewhere safe (NCSC, N.D.a; N.D.b)	Leave written passwords where other people can see them (NCSC, N.D.a)
Turn on 2-step verification, starting with email (NCSC, N.D.b)	Assume a strong password alone is enough (NCSC, N.D.b)
Change a password straight away if it has been leaked (NIST, 2025)	Change passwords on a schedule for no reason (NIST, 2025)

2. Two-Factor Authentication

Section owner: Charlie Broughton

2.1 Authentication factors

Authentication factors describe what a user must provide or demonstrate to prove their identity. NIST identifies three categories: something you know, something you have and something you are (NIST, 2025).

Something you know refers to information known by the user, such as a password, PIN or passphrase. Knowledge-based credentials can be guessed, stolen or exposed through phishing. NIST states that passwords are not phishing-resistant (NIST, 2025). Something you have refers to possession of a device or authentication token, such as a smartphone used for authentication, an authenticator app on a trusted device, a hardware security key or a token/code generator (NIST, 2025). Something you are refers to a biometric characteristic, such as a fingerprint or facial recognition (NIST, 2025).

Two passwords do not constitute 2FA simply because two credentials are being entered. Both are examples of “something you know”, so they do not represent two different authentication factors. NIST explains that multiple instances of the same factor still constitute single-factor authentication (NIST, 2025). For example, a password and PIN do not provide two different factors, whereas a password and an authenticator on a trusted device provide “something you know” and “something you have”.

2.2 Comparing SMS codes, authenticator apps and hardware security keys

SMS-based 2FA sends a one-time code to the user’s registered phone number and is widely available. However, SMS-based authentication can be attacked through SIM swapping, where an attacker persuades a mobile provider to transfer the victim’s number to a SIM controlled by the attacker. NIST also identifies risks involving telephone-number reassignment and weaknesses in the public telephone network (NIST, 2025; CISA, 2023).

Authenticator apps can generate one-time codes or provide approval notifications on a trusted device. They are generally more secure than SMS. A 2023 Microsoft research study also found that dedicated MFA applications outperformed SMS-based authentication in the dataset examined (Meyer et al., 2023). Authenticator apps are not automatically phishing-resistant. For example, an attacker can use phishing to trick a user into giving them a time-based one-time password. Push-based authentication can also suffer from “prompt fatigue” or push-bombing, where an attacker repeatedly sends approval requests hoping that the user eventually accepts one. The NCSC identifies this limitation for challenge-based authenticator apps and CISA identifies push-bombing and user error as weaknesses of ordinary push notification MFA (CISA, 2023; NCSC, 2024).

Hardware security keys are physical authentication devices that the user must possess to authenticate. FIDO2 security keys use public-key cryptography and provide strong resistance against phishing and credential theft (NCSC, 2024). The NCSC identifies FIDO2 credentials,

including roaming security keys, at the top of its recommended MFA methods because they provide strong authentication and phishing resistance (NCSC, 2024). However, FIDO2 may be less appropriate where an organisation cannot procure or effectively risk-manage a trusted device or security token (NCSC, 2024).

A peer-reviewed study of 62 banking customers found that a two-factor method using a hardware security token was perceived as more secure than single-factor authentication. However, participants rated the two-factor method lower for usability, convenience and ease of use, demonstrating a trade-off between security and usability (Gunson et al., 2011).

2.3 Evidence for the effectiveness of MFA

The widely repeated 99.9% figure can be traced to Microsoft's 2019 work. Alex Weinert's Microsoft publication reported that accounts protected by MFA were more than 99.9% less likely to be compromised (Microsoft, 2019). However, this figure came from Microsoft's research and should not be presented as a universal guarantee for every MFA implementation or every type of attack (Microsoft, 2019). The researchers analysed a large dataset of Microsoft Azure Active Directory users and found that MFA reduced the risk of account compromise by 99.22% across the population (Meyer et al., 2023). This reduced the risk by 98.56% when credentials had already been leaked and showed that dedicated MFA applications performed better than SMS-based authentication (Meyer et al., 2023).

2.4 Why SMS can still be used

The NCSC recommends that stronger MFA methods should be used where possible but also states that any message-based methods such as SMS may still provide additional protection when stronger alternatives are unavailable (NCSC, 2024). Using a second authentication factor creates an additional barrier even if an attacker has obtained the user's password (NCSC, 2024; Meyer et al., 2023). CISA similarly classifies SMS/voice MFA as a weaker option because of its vulnerabilities but recognises that it can still add protection compared with having password-only authentication (CISA, 2023).

With password-only authentication, a stolen password may allow account access. With SMS-based 2FA, the attacker must also obtain the SMS code, creating an additional barrier. Authenticator applications provide a stronger alternative to SMS in many implementations, while FIDO2 security keys provide phishing-resistant cryptographic authentication (Meyer et al., 2023; NCSC, 2024).

3. Phishing and Social Engineering

Section owner: Sorena Golbarg Lisar

3.1 Phishing and its Different Forms

Phishing

Phishing is a type of social engineering attack in which criminals impersonate a trusted organisation or individual in order to persuade victims to disclose sensitive information, transfer money, or visit a malicious website (National Institute of Standards and Technology, n.d.).

Spear Phishing

Unlike general phishing attacks, spear phishing is highly targeted. Attackers use information about a specific organisation or employee to make the message more convincing and realistic (National Cyber Security Centre, 2018).

Illustrative example of general phishing:

> *Your Disney+ account has been suspended. Click here.*

Illustrative example of spear phishing:

> *Hi Alex, I need you to check the new finance report.*

Smishing

Smishing is phishing conducted through SMS or other text messages. Attackers commonly use messages containing malicious links or other deceptive instructions to persuade victims to provide personal or financial information (Federal Bureau of Investigation, n.d.b).

Illustrative example:

> *Your parcel could not be delivered. Pay £3.50 to reschedule delivery.*

Vishing

Vishing is phishing carried out through phone calls, voice messages or Voice over Internet Protocol (VoIP). Attackers may impersonate an official organisation, such as a bank or government department, to gain trust and request personal information (Federal Bureau of Investigation, n.d.b; NCSC, 2021b).

Illustrative example:

> *I am calling from the Metropolitan Police. Someone has committed an offence using your National Insurance number. Please provide your National Insurance number so that we can verify your identity.*

Business Email Compromise (BEC)

Business Email Compromise usually targets organisations. Attackers may spoof or compromise email accounts and impersonate a colleague, manager, executive or trusted business contact. BEC often aims to persuade the victim to make a financial transfer or change payment details (Federal Bureau of Investigation, n.d.a).

Illustrative example:

> *Please transfer £10,000 to the new bank account of this supplier.*

3.2 Psychological Techniques

Phishing is not solely a technical problem; social-engineering attacks often rely on psychological techniques that influence how people respond to requests (Stylianou et al., 2025).

Authority

Authority is an important social-engineering technique because people may be more willing to follow instructions that appear to come from a manager, government organisation or other trusted authority figure (Stylianou et al., 2025). Williams et al. (2018) examined nine simulated spear-phishing emails sent to 62,000 employees and found that authority cues increased the likelihood that a user would click a suspicious link.

Urgency

Attackers often create artificial urgency by claiming that immediate action is required. This can reduce the time a victim has to evaluate a message carefully and can encourage faster decisions. Urgency is a recognised social-engineering technique in phishing messages (NCSC, 2021b; Williams et al., 2018).

Illustrative example:

> *Your account will be suspended in 50 minutes.*

Fear

Fear can influence emotional decision-making. Scam messages may make a person panic or feel threatened in order to pressure them into acting without thinking carefully (NCSC, 2021b).

Illustrative example:

> *Suspicious activity has been detected. Your bank account will be locked.*

Scarcity / Fear of Missing Out

Scarcity is used when a message suggests that an opportunity is limited or may disappear quickly. The NCSC notes that fear of missing out can make people respond more quickly to a scam message (NCSC, 2021b).

Illustrative example:

> *Only 4 places remaining. Claim your reward now or lose the opportunity.*

Overall, the effectiveness of phishing often depends on manipulating normal human responses such as trust, authority, urgency, fear and scarcity (Stylianou et al., 2025; NCSC, 2021b).

3.3 Indicators of Phishing

According to the National Cyber Security Centre (NCSC, 2026), common indicators of phishing include:

- Misspelled or suspicious email addresses
- Unexpected attachments
- Generic greetings such as “Dear valued customer”
- Links that direct users to unknown websites
- Spelling and grammar mistakes
- Poor-quality or strange-looking logos
- Messages that pressure the user to act quickly

The sender’s email address should be checked carefully because attackers may create addresses that differ from legitimate ones by only a single letter, number or symbol (Federal Bureau of Investigation, n.d.b).

Example:

Legitimate: support@paypal.com Fake: support@paypa1.com

However, users should not rely only on these signs. The NCSC explains that modern scams are becoming more convincing and can sometimes fool experienced users, so a professional-looking message should not automatically be trusted (NCSC, 2021b).

3.4 What Should Someone Do if They Suspect or Click Phishing?

If a Message Looks Suspicious

If a message appears suspicious, the recipient should not click links, open attachments or use contact details provided in the message. Instead, the organisation should be contacted independently using verified details from its official website. The user can also visit the organisation’s official website manually to check their account (NCSC, 2021b).

If the User Has Already Clicked or Shared Information

- If a password was entered, the user should change that password and any other accounts that use the same password (NCSC, 2021c).
- If banking details were shared, the user should contact their bank immediately (NCSC, 2021c).
- If a suspicious application or file was installed, the user should run a full antivirus scan and allow the security software to remove any problems it finds (NCSC, 2021c).
- If the incident happened on a work laptop or phone, the user should inform the organisation’s IT department (NCSC, 2021c).

Organisational Response

At organisational level, phishing should be addressed through multiple layers of security rather than relying entirely on employees to recognise every attack. The NCSC recommends a layered approach that combines technical, process and people-based controls (NCSC, 2018).

- Email filtering and malware detection

- Multi-factor authentication (MFA)
- Anti-spoofing controls such as SPF, DKIM and DMARC
- Security-awareness training and simple reporting processes
- Security monitoring and logging
- A documented and practised incident-response plan

Employee awareness is important, but it should not be the organisation's only defence. The NCSC states that training cannot teach users to identify every phishing attempt, so technical controls and incident-response procedures are also required (NCSC, 2018).

4. Safe Use of Devices

Section owner: Nah'Kajsha Reid

Cybersecurity depends heavily on how safely people configure and use everyday devices. Personal, financial, academic, and business information is stored in laptops, smartphones, tablets, and removable media. Using a weak device creates a potential vulnerability that could expose your data and accounts. There are several overlapping controls that could be needed to offer effective protection as opposed to a single security product. Software updating, encrypting the stored data, locking down the screens, trusted security software, and treating unknown USB connections carefully will lower the chances of an attacker succeeding. The above actions are particularly relevant since attackers usually seek to exploit vulnerabilities that they are aware of or convince a user to install malicious software on their own. The goal of using safe devices is to lessen the probability of compromise as well as the harm in case one of the defensive strategies fails.

4.1 Keeping Software Updated: Vulnerabilities, Patches, and Exploits

Software updates are important because they fix known vulnerabilities, which are weaknesses that can be exploited to violate confidentiality, integrity, or availability. An exploit is a piece of code, software, or a technique used to take advantage of a weakness in a system, whereas a patch is a change provided by a vendor to address the weakness. According to NIST, patch management can be characterised as preventive maintenance that minimises the risk of compromise, a data breach, and disruption (Souppaya and Scarfone, 2022). Likewise, the NCSC describes patches as closing established security vulnerabilities that attackers can exploit (NCSC, 2021d). Publicising a vulnerability also provides attackers with time to study the technicalities, automate the scanning process, and exploit devices that have not been updated before (NCSC, 2021d). This is why users should always keep their system updated. One notable case is the Log4Shell, CVE-2021-44228, of Apache Log4j. The Log4Shell flaw let an attacker run their own code on a system by sending crafted messages the system logs (NIST, 2021). Apache released Log4j 2.15.0 on 6 December 2021 and later strengthened protections in 2.16.0 on 13 December (Apache Software Foundation, 2021). As of 23 December 2021, agencies such as CISA have reported active exploitation and recommended organisations to upgrade affected systems promptly (CISA et al., 2021). This example shows that systems remain vulnerable until they are fixed, so any delay would cause weakness in them.

4.2 Device Encryption, Screen Locks, and Security Software

Encryption, screen locks, and security software protect various parts of the device. Encryption scrambles data so that it cannot be read without the right key. According to NIST, encryption separates the data; therefore, only authorised key holders can access it, limiting exposure in the event of a lost or stolen device (Howell et al., 2023). CISA also advises data encryption of computers, mobile gadgets, hard disks, and other pertinent files to prevent unauthorised access to data (CISA, n.d.). A screen lock stops other people from using the device, and it can use a password, a PIN or a fingerprint. Automatic lockouts lock the device after it has not been used for a while, so an unattended device cannot be used by someone else. Encryption and screen locking work hand in hand: the lock prevents access on the spot, and the encryption protects the stored data if someone tries to get around the normal login. Devices should also use reputable antivirus or endpoint security software, which can identify, prevent, or quarantine malware. According to the NCSC, modern security tools interact with operating system controls and should be updated to ensure new malware signatures and safeguards stay viable (NCSC, 2021e).

4.3 Risks of Installing Software from Unofficial Sources

Installing software from unofficial sources is risky because the package may have been modified, repackaged, or distributed without a meaningful security review. NIST suggests the vetting of apps since mobile applications can be vulnerable, have excess permissions, or malicious behaviour that compromises sensitive data (Ogata et al., 2019). The official stores do not promise that all applications are safe. However, they tend to offer better reviews, signing, upgrading, and uninstallation systems, as compared to other websites that are unknown. According to ENISA, phishing and tricking people by email are among the main ways cyber attacks begin (ENISA, 2024). Users are hence advised to ensure that the source of their downloads is verified, to avoid software that is either pirated or cracked, remove app permissions they do not need, and check unsolicited installations.

4.4 Risks of Unknown USB Devices and Public Charging Points

Unknown USB devices are harmful, as USBs might contain data and instructions, not just files or electricity. The NCSC cautions that removable media may contain malicious code and that a device like a USB Rubber Ducky can act as a keyboard and perform attacker-selected code (NCSC, 2021f). The existence of public charging points poses a similar risk since most USB connections can charge as well as provide data communication. Peer-reviewed research presented at the 2025 USENIX Security Symposium showed that malicious chargers bypassed existing confirmation protections and accessed sensitive files in tested Android and iOS devices of eight vendors (Draschbacher et al., 2025). This shows that a charger that looks normal can still be used to attack the device. Because users cannot see the inside of an unknown charger, being a public charger does not make it safe. To reduce this risk, users should: use a personal wall charger or a trusted power bank, avoid untrusted USB devices, turn off data transfer when not needed, and reject untrusted connection requests.

Safe device use, therefore, depends on layered, routine behaviour. Patches eliminate identified vulnerabilities prior to exploit success, encryption and lockouts minimise unauthorised access,

security applications aid in the detection of malicious activity, trusted software vendors reduce exposure to altered applications, and correct USB and charging practices limit physical connection attacks. None of these controls are ideal on their own, yet in combination, they drastically minimise the risk that can be avoided and increase the difficulty of compromising a device.

Conclusion

Use three random words, or at least 15 characters, for each account (NCSC, N.D.a; NIST, 2025). Don’t reuse passwords, because attackers use software to try leaked passwords on many other sites (Langlois, 2025). Let a password manager remember your passwords, and turn on 2-step verification first, starting with your email account (NCSC, N.D.b). If a password is leaked, change it straight away. Otherwise there is no need to change passwords on a schedule (NIST, 2025).

Multi-factor authentication can substantially reduce the risk of account compromise, but the methods are not equally secure. Choose a stronger, phishing-resistant method where you can. SMS codes can still add useful protection when nothing stronger is available (NCSC, 2024).

Phishing remains a significant threat because attackers combine deceptive messages with psychological techniques such as authority, urgency, fear and scarcity. Recognising the warning signs, responding quickly to anything suspicious and using several layers of organisational security can reduce the risk and impact of a successful phishing attack (National Cyber Security Centre, 2018; NCSC, 2021b).

Keeping a device safe is not about one step. It means using several protections together, such as updates, screen locks, encryption and safe downloads, and keeping them up to date. If one protection fails, the others can still stop an attacker or limit the harm. A simple step everyone can take is to keep antivirus software turned on and updated, because this lets it recognise new malware (NCSC, 2021e).

Reference List

Apache Software Foundation. (2021) *Apache Log4j 2 release notes*. [Online] Available from: https://logging.apache.org/log4j/2.x/release-notes.html. [Accessed 26 September 2026].

Cybersecurity and Infrastructure Security Agency [CISA], Federal Bureau of Investigation [FBI], National Security Agency [NSA], Australian Cyber Security Centre [ACSC], Canadian Centre for Cyber Security [CCCS], Computer Emergency Response Team New Zealand [CERT NZ], New Zealand National Cyber Security Centre [NZ NCSC] and United Kingdom National Cyber Security Centre [NCSC-UK]. (2021) *Mitigating Log4Shell and other Log4j-related vulnerabilities*. [Online] Available from: https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-356a. [Accessed 26 September 2026].

Cybersecurity and Infrastructure Security Agency [CISA]. (2023) *Implementing phishing-resistant MFA*. [Online] Available from: https://www.cisa.gov/sites/default/files/2023-01/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf. [Accessed 28 September 2026].

Cybersecurity and Infrastructure Security Agency [CISA]. (n.d.) *How to protect the data that is stored on your devices*. [Online] Available from: https://www.cisa.gov/resources-tools/training/how-protect-data-stored-your-devices. [Accessed 26 September 2026].

Das, A., Bonneau, J., Caesar, M., Borisov, N. and Wang, X. (2014) The tangled web of password reuse. In: *Network and Distributed System Security Symposium (NDSS 2014)*. San Diego, 23-26 February 2014. [Online] Available from: https://www.ndss-symposium.org/ndss2014/ndss-2014-programme/tangled-web-password-reuse/. [Accessed 25 September 2026].

Department for Science, Innovation and Technology. (2025) *Cyber security breaches survey 2025*. [Online] Available from: https://www.gov.uk/government/statistics/cyber-security-breaches-survey-2025/cyber-security-breaches-survey-2025. [Accessed 29 September 2026].

Draschbacher, F., Maar, L., Oberhuber, M., and Mangard, S. (2025) ChoiceJacking: compromising mobile devices through malicious chargers like a decade ago. In: *34th USENIX Security Symposium*. [Online] pp. 4363–4379. Available from: https://www.usenix.org/conference/usenixsecurity25/presentation/draschbacher. [Accessed 26 September 2026].

European Union Agency for Cybersecurity [ENISA]. (2024) *Promoting security in the digital world during the European Cybersecurity Month*. [Online] Available from: https://www.enisa.europa.eu/news/promoting-security-in-the-digital-world-during-the-european-cybersecurity-month. [Accessed 26 September 2026].

Federal Bureau of Investigation. (n.d.a) *Business email compromise*. [Online] Available from: https://www.fbi.gov/how-we-can-help-you/common-frauds-and-scams/business-email-compromise. [Accessed 30 September 2026].

Federal Bureau of Investigation. (n.d.b) *Spoofing and phishing*. [Online] Available from: https://www.fbi.gov/how-we-can-help-you/common-frauds-and-scams/spoofing-and-phishing. [Accessed 30 September 2026].

Gunson, N., Marshall, D., Morton, H. and Jack, M. (2011) User perceptions of security and usability of single-factor and two-factor authentication in automated telephone banking. *Computers & Security*, 30(4), pp. 208-220. Available from: https://doi.org/10.1016/j.cose.2010.12.001.

Howell, G., Franklin, J., Sritapan, V., Souppaya, M., and Scarfone, K. (2023) *Guidelines for managing the security of mobile devices in the enterprise*. NIST Special Publication 800-124 Revision 2. [Online] Available from: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-124r2.pdf. [Accessed 26 September 2026].

Information Commissioner's Office. (2025) *23andMe fined £2.31 million for failing to protect UK users' genetic data*. [Online] Available from: https://ico.org.uk/about-the-ico/media-centre/news-and-blogs/2025/06/23andme-fined-for-failing-to-protect-uk-users-genetic-data/. [Accessed 25 September 2026].

Langlois, P. (2025) *Additional 2025 DBIR research on credential stuffing*. [Online] Verizon Business. Available from: https://www.verizon.com/business/resources/articles/credential-stuffing-attacks-2025-dbir-research/. [Accessed 25 September 2026].

Meyer, L.A., Romero, S., Bertoli, G., Burt, T., Weinert, A. and Lavista Ferres, J.M. (2023) *How effective is multifactor authentication at deterring cyberattacks?* [Online] arXiv. Available from: https://arxiv.org/abs/2305.00945. [Accessed 28 September 2026].

Microsoft. (2019) *Your Pa$$word doesn't matter*. [Online] Available from: https://techcommunity.microsoft.com/blog/microsoft-entra-blog/your-paword-doesnt-matter/731984. [Accessed 30 September 2026].

National Cyber Security Centre. (2018) *Phishing attacks: defending your organisation*. [Online] Available from: https://www.ncsc.gov.uk/guidance/phishing. [Accessed 30 September 2026].

National Cyber Security Centre. (2021a) *The logic behind three random words*. [Online] Available from: https://www.ncsc.gov.uk/blog-post/the-logic-behind-three-random-words. [Accessed 25 September 2026].

National Cyber Security Centre. (2021b) *Phishing scams: how to spot and report them*. [Online] Available from: https://www.ncsc.gov.uk/collection/phishing-scams/spot-scams. [Accessed 30 September 2026].

National Cyber Security Centre. (2021c) *Phishing scams: if you've shared sensitive information*. [Online] Available from: https://www.ncsc.gov.uk/collection/phishing-scams/what-to-do. [Accessed 30 September 2026].

National Cyber Security Centre. (2021d) *Keeping devices and software up to date*. [Online] Available from: https://www.ncsc.gov.uk/collection/device-security-guidance/managing-deployed-devices/keeping-devices-and-software-up-to-date. [Accessed 26 September 2026].

National Cyber Security Centre. (2021e) *Antivirus and other security software*. [Online] Available from: https://www.ncsc.gov.uk/collection/device-security-guidance/policies-and-settings/antivirus-and-other-security-software. [Accessed 26 September 2026].

National Cyber Security Centre. (2021f) *Using peripherals securely*. [Online] Available from: https://www.ncsc.gov.uk/collection/device-security-guidance/policies-and-settings/using-peripherals-securely. [Accessed 26 September 2026].

National Cyber Security Centre. (2024) *Multi-factor authentication for your corporate online services: recommended types of MFA*. [Online] Available from: https://www.ncsc.gov.uk/collection/mfa-for-your-corporate-online-services/recommended-types-of-mfa. [Accessed 28 September 2026].

National Cyber Security Centre. (2026) *Small organisations guide to cyber security: spotting cyber attacks*. [Online] Available from: https://www.ncsc.gov.uk/collection/small-organisations-guide-to-cyber-security/spotting-cyber-attacks. [Accessed 30 September 2026].

National Cyber Security Centre. (N.D.a) *Three random words*. [Online] Available from: https://www.ncsc.gov.uk/collection/top-tips-for-staying-secure-online/three-random-words. [Accessed 25 September 2026].

National Cyber Security Centre. (N.D.b) *Managing your passwords*. [Online] Available from: https://www.ncsc.gov.uk/collection/top-tips-for-staying-secure-online/password-managers. [Accessed 25 September 2026].

National Cyber Security Centre. (N.D.c) *What we do at the NCSC*. [Online] Available from: https://www.ncsc.gov.uk/section/about-ncsc/what-we-do. [Accessed 29 September 2026].

National Institute of Standards and Technology. (2021) *CVE-2021-44228 detail: Apache Log4j2 JNDI features do not protect against attacker-controlled LDAP and other JNDI-related endpoints*. National Vulnerability Database. [Online] Available from: https://nvd.nist.gov/vuln/detail/CVE-2021-44228. [Accessed 26 September 2026].

National Institute of Standards and Technology. (2025) *Digital identity guidelines: authentication and authenticator management (NIST Special Publication 800-63B-4)*. [Online] Gaithersburg, MD: NIST. Available from: https://pages.nist.gov/800-63-4/sp800-63b.html. [Accessed 25 September 2026].

National Institute of Standards and Technology. (n.d.) *Phishing*. [Online] Available from: https://csrc.nist.gov/glossary/term/phishing. [Accessed 30 September 2026].

Oesch, S. and Ruoti, S. (2020) That was then, this is now: a security evaluation of password generation, storage, and autofill in browser-based password managers. In: *Proceedings of the 29th USENIX Security Symposium*. August 2020. [Online] Berkeley, CA: USENIX Association, pp. 2165-2182. Available from: https://www.usenix.org/conference/usenixsecurity20/presentation/oesch. [Accessed 25 September 2026].

Ogata, M., Franklin, J., Voas, J., Sritapan, V., and Quirolgico, S. (2019) *Vetting the security of mobile applications*. NIST Special Publication 800-163 Revision 1. [Online] Available from: https://www.nist.gov/publications/vetting-security-mobile-applications-0. [Accessed 26 September 2026].

Pearman, S., Zhang, S.A., Bauer, L., Christin, N. and Cranor, L.F. (2019) Why people (don't) use password managers effectively. In: *Fifteenth Symposium on Usable Privacy and Security (SOUPS 2019)*. Santa Clara, CA, August 2019. [Online] Berkeley, CA: USENIX Association, pp. 319-338. Available from: https://www.usenix.org/conference/soups2019/presentation/pearman. [Accessed 25 September 2026].

Shay, R., Komanduri, S., Durity, A.L., Huh, P.S., Mazurek, M.L., Segreti, S.M., Ur, B., Bauer, L., Christin, N. and Cranor, L.F. (2016) Designing password policies for strength and usability. *ACM Transactions on Information and System Security*, [Online] 18(4), pp. 1-34. Available from: https://doi.org/10.1145/2891411. [Accessed 25 September 2026].

Souppaya, M. and Scarfone, K. (2022) *Guide to enterprise patch management planning: Preventive maintenance for technology*. NIST Special Publication 800-40 Revision 4. [Online] Available from: https://csrc.nist.gov/pubs/sp/800/40/r4/final. [Accessed 26 September 2026].

Stylianou, I., Bountakas, P., Zarras, A. and Xenakis, C. (2025) Suspicious minds: psychological techniques correlated with online phishing attacks. *Computers in Human Behavior Reports*, [Online] 19, article 100694. Available from: https://doi.org/10.1016/j.chbr.2025.100694. [Accessed 30 September 2026].

Verizon. (2025) *Verizon's 2025 Data Breach Investigations Report: alarming surge in cyberattacks through third-parties*. [Online] Available from: https://www.verizon.com/about/news/2025-data-breach-investigations-report. [Accessed 29 September 2026].

Williams, E.J., Hinds, J. and Joinson, A.N. (2018) Exploring susceptibility to phishing in the workplace. *International Journal of Human-Computer Studies*, [Online] 120, pp. 1-13. Available from: https://doi.org/10.1016/j.ijhcs.2018.06.004. [Accessed 30 September 2026].